

Assets Threats & securities

- to learn

- ① assets organization protect
- ② security systems and controls
- ③ common vulnerability in system
- ④ Threat to asset security

Module - 1

- ↳ Assets threat and vulnerabilities
- ↳ Asset inventories
- ↳ Challenges in rapidly changing digital world
- ↳ Policies, standards and procedures.
- ↳ NIST Cybersecurity Framework.

Assets Classification

Assets inventory : A Catalog of Assets that need to be protected



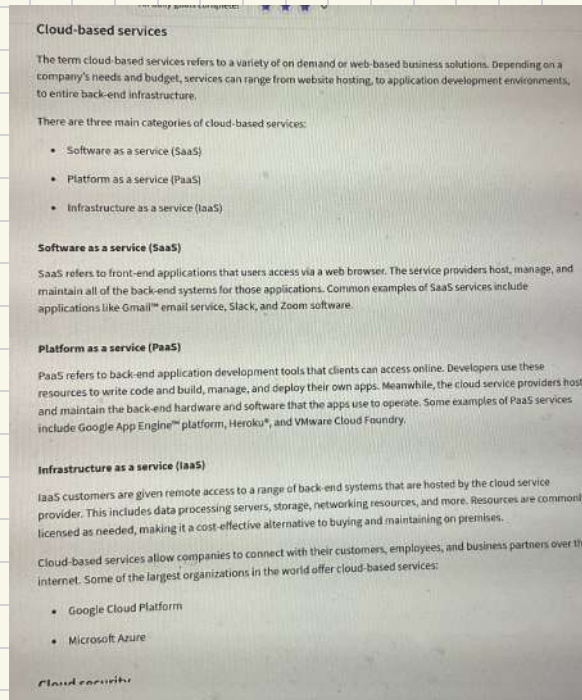
Level of Assets Classification

- ① Public
- ② Internal only
- ③ Confidential
- ④ Restricted

Assets in digital world

3 states of data

- ① In use
- ② In transit
- ③ At rest



Types of risk categories

- Damage
- Disclosure
- Loss of information

Elements of security Plan

- **Policies** :- A set of rule that reduces risk and protects information.
- **Standards** :- references that inform how to set Policies.
- **Procedures** :- set by step How to perform a specific security task

NIST Cybersecurity framework.

Compliance :- The process of adhering to internal standards or external regulations

Regulations are set by a government or other Authority to control the way something is done

NIST CSF :- A voluntary framework that consists of standards, guidelines, and best practices to manage cybersecurity risk

Security guideline in Action

↳ Components

- **Core** :- The CSF core is a set of desired cybersecurity outcomes that help organisation customize their security plan consist of 6 function used as a reference
- **Tiers** :- The tiers are a way of measuring the sophistication of an organisation cybersecurity program. measured in the scale of 1 to 4
- **Profiles** :- The CSF Profile are pre-made template of the NIST CSF that are developed by a team of industry experts. they are tailored to address the specific risk of an organisation or industry.

five functions of the NIST CSF core

- Identify
- Protect
- Detect
- Respond
- Recover

Module = 2

↳ To learn

- ① Effective data handling Processes
- ② the Role of encryption and hashing in safeguarding information

Security Controls.

Safeguard designed to reduce specific security risk

Types of Security Controls

- Technical
- Operational
- Managerial

Information Privacy.

the protection of unauthorized access and distribution of data

Data Owner :- the person that decides who can access, edit, use or destroy their information

Data Custodian :- Anyone or anything that's responsible for the safe handling, transport, and storage of information

Principal of least Privilege

The common types of user account

- ① **Guest accounts** :- are provided to external users who need to access an internal network like customers, clients, contractors or business partners
- ② **users accounts** :- are assigned to staff based on their job duties
- ③ **Service accounts** :- are granted to applications or software that need to interact with other software on the network
- ④ **Privileged accounts** : have elevated permission or administrative access

Auditing account Privileges

- ① usage Audit
- ② Privilege Audit
- ③ Account Change Audits

usage
audit

when conducting a usage audits, the security team will review which resource each account is accessing and what the user is doing with the resource.

Privilege Audits when conducting Privilege Audit the security team will review which resource each accounting

Account Change Audit :- Keeps records and logs associated with each user.

The data lifecycle

An important model that security team consider when protecting information. It influences how they set policies that align with business objects

Five Stages of data lifecycle

- collect
- Store
- use
- archive
- Destroy

Data governance: is a set of process that define how an organization manages information. Governance often includes policies that specify how to keep data private, accurate, available and secure throughout its lifecycle.

Data governance policies commonly categorize individuals into specific role:

Data Owner: the person that decides who can access, edit, use or destroy their information.

Data Custodian: anyone or anything that's responsible for the safe handling, transport and storage of information.

1) **Data steward:** the person or group that maintains and implements data governance policies set by an organization.

Fundamentals of Cryptography.

Cryptography: the process of transforming information into a form that unintended readers can't understand

Message $\rightarrow$ Encryption $\rightarrow$ Cipher text $\rightarrow$ Decryption $\rightarrow$ Message

Algorithm $\rightarrow$ a set of rules that solve a problem

Cipher $\rightarrow$ algorithm that encrypts information

Cryptographic Key $\rightarrow$ a mechanism that decrypts cipher text

Brute force attack

A trial and error process of discovering private information

Public Key infrastructure

PKI is a encryption framework that secure the exchange of information online.

It is a two step process

① Exchange of encrypted information

Involves either asymmetric encryption & symmetric encryption or Both

Asymmetric encryption :- The use of Public and Private Pair for encryption and decryption of data

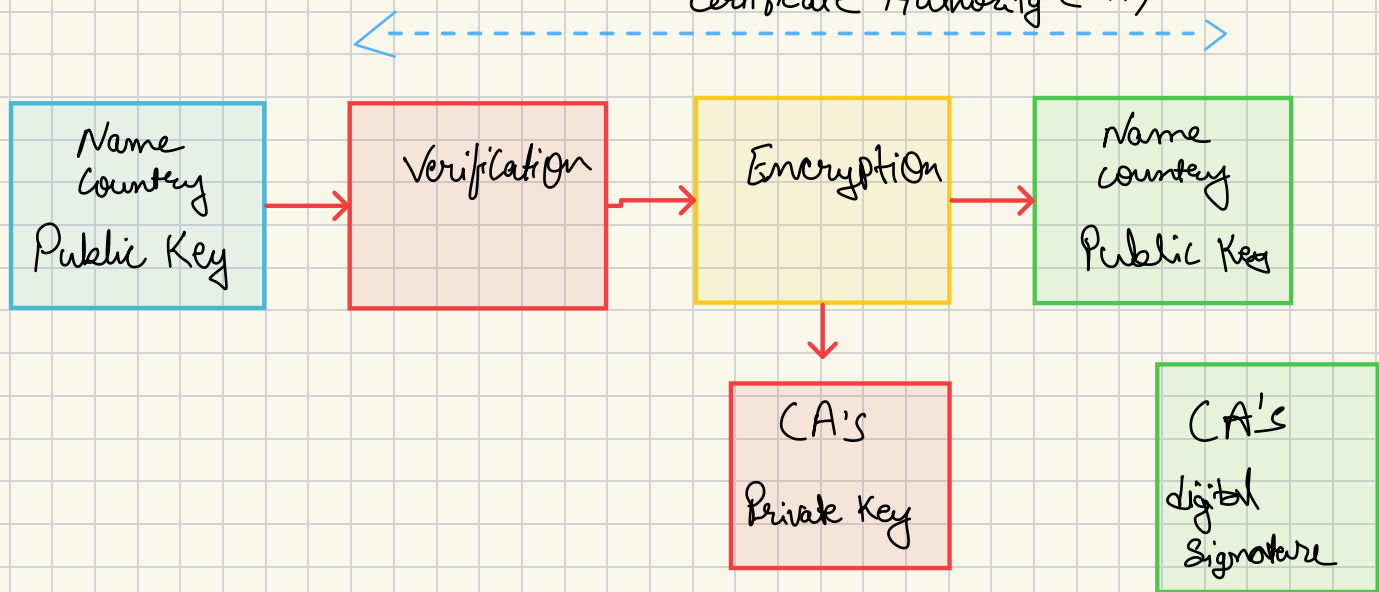
Symmetric encryption :- The use of Single Secret Key to exchange information

② Establish trust using a System of Digital Certificates

Digital Certificates :- A file that verifies the Identity of a Public Key Public

Obtaining a digital Certificate

Certificate Authority (CA)



Symmetric algorithms

- *Triple DES (3DES)* is known as a block cipher because of the way it converts plaintext into ciphertext in "blocks." Its origins trace back to the Data Encryption Standard (DES), which was developed in the early 1970s. DES was one of the earliest symmetric encryption algorithms that generated 64-bit keys, although only 56 bits are used for encryption. A **bit** is the smallest unit of data measurement on a computer. As you might imagine, Triple DES generates keys that are three times as long. Triple DES applies the DES algorithm three times, using three different 56-bit keys. This results in an effective key length of 168 bits. Despite the longer keys, many organizations are moving away from using Triple DES due to limitations on the amount of data that can be encrypted. However, Triple DES is likely to remain in use for backwards compatibility purposes.
- *Advanced Encryption Standard (AES)* is one of the most secure symmetric algorithms today. AES generates keys that are 128, 192, or 256 bits. Cryptographic keys of this size are considered to be safe from brute force attacks. It's estimated that brute forcing an AES 128-bit key could take a modern computer billions of years!

Asymmetric algorithms

- *Rivest Shamir Adleman (RSA)* is named after its three creators who developed it while at the Massachusetts Institute of Technology (MIT). RSA is one of the first asymmetric encryption algorithms that produces a public and private key pair. Asymmetric algorithms like RSA produce even longer key lengths. In part, this is due to the fact that these functions are creating two keys. RSA key sizes are 1,024, 2,048, or 4,096 bits. RSA is mainly used to protect highly sensitive data.
- *Digital Signature Algorithm (DSA)* is a standard asymmetric algorithm that was introduced by NIST in the early 1990s. DSA also generates key lengths of 2,048 bits. This algorithm is widely used today as a complement to RSA in public key infrastructure.

Non-Repudiation and hashing

Hash - Function:- An algorithm that produces a code that can't be decrypted instead produce unique identifiers known as hash value

we can use hash value to determine the integrity of files because if there is any change in file it will produce different hash value

Non-Repudiation: The concept that the authenticity of info can't be denied

we can use linux to get hash value of any file

Ex:- Name of hashing algorithm - filename

sha256sum Newfile.txt
|
hashing
algorithm

These can be compared with known hash value of virus
one such database is **VirusTotal**

Origins of hashing

Hash functions have been around since the early days of computing. They were originally created as a way to quickly search for data. Since the beginning, these algorithms have been designed to represent data of any size as small, fixed-size values, or digests. Using a hash table, which is a data structure that's used to store and reference hash values, these small values became a more secure and efficient way for computers to reference data.

One of the earliest hash functions is Message Digest 5, more commonly known as MD5. Professor Ronald Rivest of the Massachusetts Institute of Technology (MIT) developed MD5 in the early 1990s as a way to verify that a file sent over a network matched its source file.

Whether it's used to convert a single email or the source code of an application, MD5 works by converting data into a 128-bit value. You might recall that a **bit** is the smallest unit of data measurement on a computer. Bits can either be a 0 or 1. In a computer, bits represent user input in a way that computers can interpret. In a hash table, this appears as a string of 32 characters. Altering anything in the source file generates an entirely new hash value.

Generally, the longer the hash value, the more secure it is. It wasn't long after MD5's creation that security practitioners discovered 128-bit digests resulted in a major vulnerability.

Here is an example of how plaintext gets turned into hash values:

Five functions make up the SHA family of algorithms:

- SHA-1
- SHA-224
- SHA-256
- SHA-384
- SHA-512

Secure password storage

Passwords are typically stored in a database where they are mapped to a username. The server receives a request for authentication that contains the credentials supplied by the user. It then looks up the username in the database and compares it with the password that was provided and verifies that it matches before granting them access.

This is a safe system unless an attacker gains access to the user database. If passwords are stored in plaintext, then an attacker can steal that information and use it to access company resources. Hashing adds an additional layer of security. Because hash values can't be reversed, an attacker would not be able to steal someone's login credentials if they managed to gain access to the database.

Rainbow tables

A **rainbow table** is a file of pre-generated hash values and their associated plaintext. They're like dictionaries of weak passwords. Attackers capable of obtaining an organization's password database can use a rainbow table to compare them against all possible values.

Adding some "salt"

Functions with larger digests are less vulnerable to collision and rainbow table attacks. But as you're learning, no security control is perfect.

Salting is an additional safeguard that's used to strengthen hash functions. A *salt* is a random string of characters that's added to data before it's hashed. The additional characters produce a more unique hash value, making salted data resilient to rainbow table attacks.

For example, a database containing passwords might have several hashed entries for the password "password." If those passwords were all salted, each entry would be completely different. That means an attacker using a rainbow table would be unable to find matching values for "password" in the database.

Hash collisions

One of the flaws in MD5 happens to be a characteristic of all hash functions. Hash algorithms map any input, regardless of its length, into a fixed-size value of letters and numbers. What's the problem with that? Although there are an infinite amount of possible inputs, there's only a finite set of available outputs!

MD5 values are limited to 32 characters in length. Due to the limited output size, the algorithm is considered to be vulnerable to **hash collision**, an instance when different inputs produce the same hash value. Because hashes are used for authentication, a hash collision is similar to copying someone's identity. Attackers can carry out collision attacks to fraudulently impersonate authentic data.

Next-generation hashing

To avoid the risk of hash collisions, functions that generated longer values were needed. MD5's shortcomings gave way to a new group of functions known as the Secure Hashing Algorithms, or SHAs.

The National Institute of Standards and Technology (NIST) approves each of these algorithms. Numbers besides each SHA function indicate the size of its hash value in bits. Except for SHA-1, which produces a 160-bit digest, these algorithms are considered to be collision-resistant. However, that doesn't make them invulnerable to other exploits.

Access controls and Authentication System

Access Control:- A Security controls that manage access, authorization, and accountability of information

AAA framework

- Authentication
- Authorization
- Accounting

Authentication:-

has one task ask the person accessing info who are you

Factors of Authentication

① **Knowledge:-** Something the user knows

② **Ownership :-** Something the user possesses

③ **Characteristic :-** Something the user is

SSO Single Sign On:- A Technology that combines several different logins into one

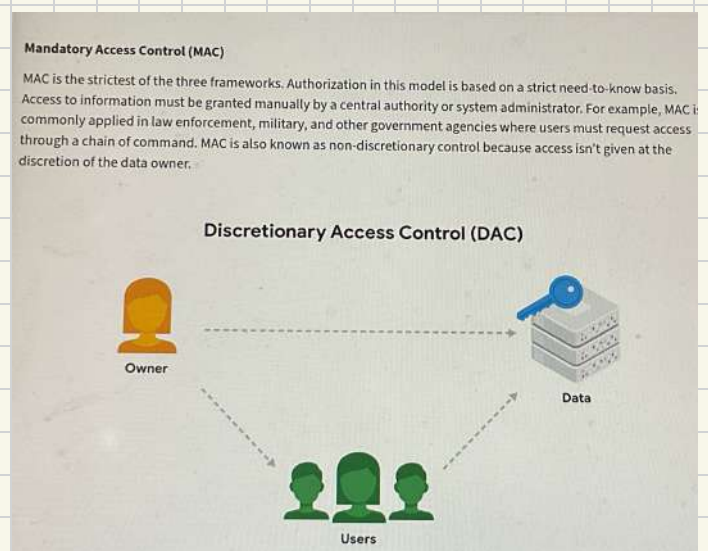
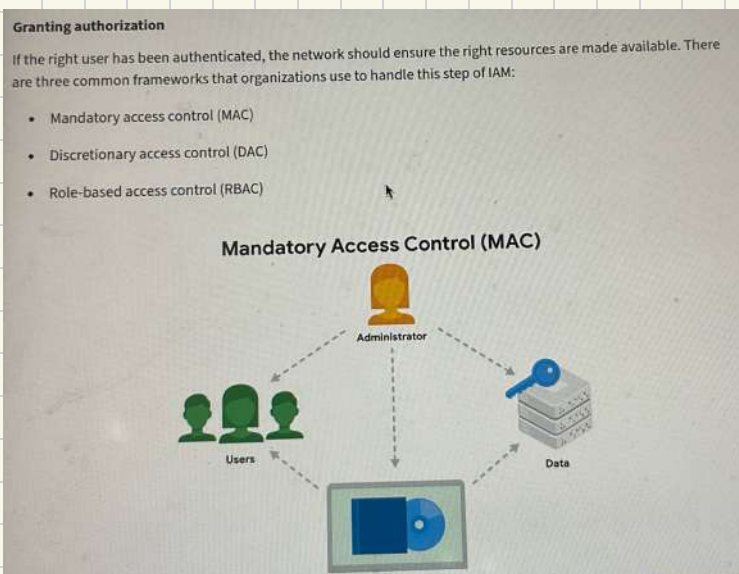
Multi factor Authentication (MFA): A security measure which require a user to verify their identity in two or more ways to access a system or network

Session:- A sequence of network HTTP basic auth requests and response associated with same user

Session ID:- A unique token that identifies a user and their device while accessing the system

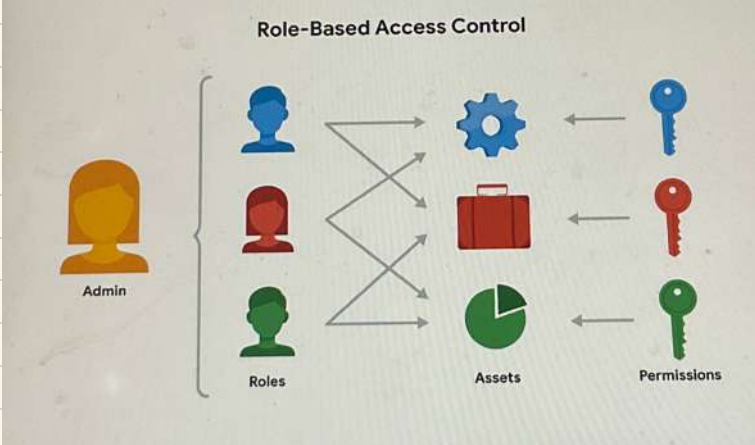
Session Cookie:- A Token that website use to validate a session and determine how long that session should last

Session Hijacking:- An event when attacker obtain legitimate user's session ID



Discretionary Access Control (DAC)

DAC is typically applied when a data owner decides appropriate levels of access. One example of DAC is when the owner of a Google Drive folder shares editor, viewer, or commentor access with someone else.



Vulnerabilities System

what to learn

- Vulnerability management Process
- Defense in depth model
- The CVE list
- Attack Surfaces

Vulnerability management

Vulnerability: A weakness that can be exploited by a Threat

Exploit: A way of taking advantage of a vulnerability

Vulnerability management is a process of finding and patching vulnerabilities.

It is a 4 step process

Module - 3

Vulnerability managements

- ① Identify managment
- ② Consider potential Exploits
- ③ Prepare defense against threat
- ④ Evaluate the Defense

Zero day Exploit :- An exploit that was previously unknown

also Exploit happening in real time with zero days to fix it

Vulnerabilities of CI/CD

what is CI/CD ?

Continuous Integration/ Continuous Delivery and Continuous deployment Pipelines are essential for modern software development. help teams delivery Software faster and more efficiently

CI/CD automates the entire software release process, from code creation to deployment.

Building solid foundation

CI is all about frequently merging code changes from different developers into a central location. This triggers automated process like building the software and running tests. CI catches problem through automated process. Every time code is integrated the system automatically builds and tests it. This feedback loop reveals integration problem as soon as they occur.

Ready to release

Continuous Delivery (CD)

means your code is always ready to be released to users after passing automated, code automatically deployed to staging environment or prepared for final release. Typically needs manual approval step before going live.

Fully automated release

Continuous deployment automates entire release process.

"Changes that pass all automated checks are automatically deployed directly to production environment with no ~~more~~ manual approval."

all about speed and efficiency

Security benefits of CD & D

The Automated security checks are:

• Dynamic Application Security Testing (DAST)

Automated test that find vulnerabilities in running application in realistic staging environments.

- Security Compliance Check:

Automated checks that ensure software meets your organizations security rules and policies

Infrastructure security validation

Checks that make sure the system hosting your software are secure

What to watch out for

Insecure dependencies:- Risk from third-party code
CI/CD Pipeline often use many third-party libraries and components. If these component have known vulnerabilities

Action Step:- Regular scan and update your dependencies. Make sure you're using secure version of all external components.

Misconfigured permission : Controlling Access

Weak access control in CI/CD tools, code repositories and related systems are a significant vulnerabilities.

Unauthorized access can allow to modify code, Pipeline configuration, or inject malicious content.

Action Step : Implement strong access management use Role-Based Access Control (RBAC). Ensure only authorized individual can access and change critical pipeline elements.

Lack of Automated Security Testing : Missing Critical Checks

Failing to include automated security in your CI/CD pipeline is a serious error. Without tools like SAST and DAST, you are almost guaranteed to release software full of vulnerabilities that will go undetected until after it's live.

Action Step - Integrated automated security testing (SAST and DAST) into your CI/CD pipeline.

Exposed secrets: Protecting sensitive information

Hardcoding sensitive data like API Keys, Passwords and token directly into code or pipeline setting is a serious security mistake

Action Step:- Never Hardcode Security

Unsecured Builds environments: Protecting the Pipeline Infrastructure

The CI/CD environments needs to be secure

Action Step:- Harden your build environment

Building a Secure CI/CD Pipeline: Defense in Depth

To proactively address these vulnerabilities, a layered security approach is key. Here are essential best practices for your CI/CD security strategy:

- **Integrate Security from the Start: Embrace DevSecOps:** Adopt a **DevSecOps** mindset. This means building security into every stage of development, from planning to deployment and beyond. This naturally includes embedding security checks into your CI/CD pipeline.
- **Implement Strong Access Controls:** Use strict permission policies based on the principle of least privilege. Only grant necessary access to code, pipeline settings, and deployment configurations. Use tools like Multi-Factor Authentication (MFA) and Role-Based Access Control (RBAC) to secure your CI/CD environment.
- **Automate Security Testing Everywhere:** Make automated security scans and tests a fundamental part of your build and deployment process. Tools like SAST, Software Composition Analysis (SCA), and DAST are not optional extras – they are essential for a secure CI/CD pipeline so you can catch vulnerabilities early.
- **Keep Dependencies Updated:** Maintain a current inventory of all third-party dependencies, libraries, and CI/CD plugins. Regularly update these components to patch security vulnerabilities (CVEs). Tools like [Dependabot](#) and [Snyk](#) can automate dependency management.
- **Secure Secrets Management:** Never hardcode sensitive information in your code or pipeline configurations. Require the use of dedicated secrets management tools like HashiCorp Vault or AWS Secrets Manager. Securely store, access, and rotate secrets throughout the CI/CD process.

Defense in depth strategy

A layered approach to vulnerability management to reduce risk

(Castle Approach)

In Cyber world we have 5 layers

- ① Perimeter layer : let only trusted Partner to next layer (Authentication)
- ② Network layer :- firewalls (Authorization)
- ③ Endpoint layer :- (Antivirus) and similar
- ④ Application layer :- All Interface use to interact with technology (MFA)
- ⑤ Data layer :- PII

Common vulnerabilities and exposure

Not Public lib

Exposure :- Is a mistake that can be exploited by a threat

CVE[®] list Common vulnerabilities and exposure

An openly accessible dictionary of known vulnerabilities and exposure.

Originally Created by MITRE Corp 1999

A collection of Non-Profit research and development centers sponsored by US Government.

To add anything to CVE list it needs to pass through
(CNA) CVE Numbering Authority.

An organization that volunteers to analyze and distribute information on eligible CVEs.

CVE Test 4 Criteria for vulnerability to be assigned an ID

- ① Independent of other Issue :- Can be fixed without having to fix something else
- ② Recognised as potential security risk
- ③ Submitted with evidence

④ Only affect one codebase :- only one program
Source code

Only after these 4 step vulnerability is added
to CVE list.

The NIST Vulnerabilities Database use Common Vulnerability
Scoring System (CVSS)

A measurement system that scores the severity of
a vulnerability. on scale of 0 to 10

below 4.0 CVSS score is low risk

anything above 9.0 CVSS score is critical risk

OWASP TOP 10

what is OWASP?

a non profit foundation and an open platform that security
professional from around the world use to share information
tools and events that are focused on securing the
web

OWASP is a list published since 2003 of
web's most targeted vulnerabilities updated every
few years

Common vulnerabilities

- ① Broken access control - limit what user can do in webapp
- ② Cryptographic failures - Encryption failure
- ③ Injecting :- when malicious code is inserted into vulnerable application
- ④ Insecure design :- security controls programmed into application
- ⑤ Security misconfiguration :- when settings aren't set properly
- ⑥ vulnerable and outdated components : using Bad libraries & API
- ⑦ Identification and Authentication failure :- fails to identify who has access and who should have
- ⑧ Software and data integrity failures :- when update patches are inadequately reviewed before implementation. Attacker can use weakness to deliver malicious software

← Famous Example of Supply Chain attack
Solar wind attack 2020

9

Security logging and monitoring failures:

- able to log and trace back events.

10

Server side request forgery (SSRFs)

- when attacker manipulates the normal operation of server to read or update other resource on server

Identifying System Vulnerabilities

Vulnerability assessment :- An Internal review process of an organization's security systems.

vulnerability assessment process

- Identification
- Vulnerability analysis
- Risk assessment (severity score)
- Remediation

Approaches to vulnerability Scanning

we can use vulnerability scanner to identify weakness and prevent attack

A vulnerability Scanner is a software that automatically compare known vulnerability and exposure against the tech on the Network.

They are used to analyze risk of the five attack Surface that learned about in

- ① Perimetric layer:- like authentication system that validate user access
- ② Network layer:- which is made up tech like Network firewall and other
- ③ Endpoint layer:- which describe devices on a Network like laptop, desktop
- ④ Application layer:- which involves the software that users interact with
- ⑤ Data layer:- Include any information that's stored, in transit, or in use

External vs. internal

External and internal scans simulate an attacker's approach.

External scans test the perimeter layer outside of the internal network. They analyze outward facing systems, like websites and firewalls. These kinds of scans can uncover vulnerable things like vulnerable network ports or servers.

Internal scans start from the opposite end by examining an organization's internal systems. For example, this type of scan might analyze application software for weaknesses in how it handles user input.

Authenticated vs. unauthenticated

Authenticated and unauthenticated scans simulate whether or not a user has access to a system.

Authenticated scans might test a system by logging in with a real user account or even with an admin account. These service accounts are used to check for vulnerabilities, like broken access controls.

Unauthenticated scans simulate external threat actors that do not have access to your business resources. For example, a scan might analyze file shares within the organization that are used to house internal-only documents. Unauthenticated users should receive "access denied" results if they tried opening these files. However, a vulnerability would be identified if you were able to access a file.

Limited vs. comprehensive

Limited and comprehensive scans focus on particular devices that are accessed by internal and external users.

Limited scans analyze particular devices on a network, like searching for misconfigurations on a firewall.

Comprehensive scans analyze all devices connected to a network. This includes operating systems, user databases, and more.

Pro tip: Discovery scanning should be done prior to limited or comprehensive scans. Discovery scanning is used to get an idea of the computers, devices, and open ports that are on a network.

Penetration Testing

A simulated attack that helps identifies vulnerability in systems, network, websites, application, and processes

Same tools and technique as malicious actors in order to mimic a real life attack

Penetration testing strategies

There are three common penetration testing strategies:

- **Open-box testing** is when the tester has the same privileged access that an internal developer would have—information like system architecture, data flow, and network diagrams. This strategy goes by several different names, including internal, full knowledge, white-box, and clear-box penetration testing.
- **Closed-box testing** is when the tester has little to no access to internal systems—similar to a malicious hacker. This strategy is sometimes referred to as external, black-box, or zero knowledge penetration testing.
- **Partial knowledge testing** is when the tester has limited access and knowledge of an internal system—for example, a customer service representative. This strategy is also known as gray-box testing.

Closed box testers tend to produce the most accurate simulations of a real-world attack. Nevertheless, each strategy produces valuable results by demonstrating how an attacker might infiltrate a system and what information they could access.

Becoming a penetration tester

Penetration testers are in-demand in the fast growing field of cybersecurity. All of the skills you're learning in this program can help you advance towards a career in pen testing:

- Network and application security
- Experience with operating systems, like Linux
- Vulnerability analysis and threat modeling
- Detection and response tools
- Programming languages, like Python and BASH
- Communication skills

Programming skills are very helpful in penetration testing because it's often performed on software and IT systems. With enough practice and dedication, cybersecurity professionals at any level can develop the skills needed to be a

Pathways through defenses

Attack vectors: the Pathway attackers use to penetrate security defense

attacker mindset

- ① Identify a target
- ② Determine how the target can be accessed
- ③ Evaluate the attack vectors
- ④ Find the tools and methods of attack

Defending attack vectors

- ① educating users
- ② Apply least Privilege
- ③ using the right security control and tools
- ④ Building diverse security team

Module - 4

To learn

- Social Engineering
- Malware
- web Exploit
- Threat Modeling Process

The art of persuasion

Social engineering :: A manipulation technique that exploit human error to gain private information, access or valuable

Stages of social engineering

- (1) Prepare
- (2) Establish trust
- (3) Use persuasion tactics
- (4) Disconnect from target

Prevention to Social Engineering

- (1) Implementing managerial controls.
- (2) Staying informed of trends
- (3) Sharing your knowledge with others.

Tactics of Social Engineering

High Profile Example is Twitter Hack of 2020

Signs of attack

The common types of social engineering

- Baiting is a social engineering tactic to tempt people into compromising their security (Rubber ducky)
- Phishing:- is the digital communication to trick people into revealing sensitive data or deploying malicious software
- quid pro quo:- trick someone into believing that they will be rewarded in exchange of access, info or money
- tailgating:- where attacker follow an unauthorized person into a restricted area
- watering hole is a type of attack when threat actor compromise a website frequently visited by a specific group of user. often these watering hole sites are infected with malicious software
Ex Holy water attack 2020 infected various religious, charity, and volunteer website

Phishing for information

Phishing Kit is a collection of software tools needed to launch a Phishing Campaign

- malicious attachment
- Fake data-collection form
- Fraudulent web links

Smishing - the use of text message to obtain sensitive information or to impersonate a known source

Phishing Security measure

- Anti-Phishing Policies
- Employee training resource
- Email filter
- Intrusion Prevention System

web based Exploits

malicious code or behaviour that's used to take advantage of coding flaws in web application using injection attack

Cross-Site Scripting (XSS)

An injection attack that insert code into a vulnerable website or web-application

commonly -- HTML, Java

Types of cross-site scripting attacks

- ① Reflected
- ② Stored
- ③ DOM-Based

① Reflected XSS attack: An instance when malicious script is sent to a server and activated during server's response (fake page)

② stored XSS attack:- An instance when malicious script is injected directly on the server (elements of website)

③ DOM - Base model (Document object Model)
XSS - A instance when malicious Script exist in the webpage a browser loads
(can be seen in URL)

Database Exploit

SQL injection :- An attack that executes unexpected queries on a database

Ex login forms

Prevention :- Prepared statements ①

A coding technique that executes SQL statement before passing them on to the Database

- ② Input Sanitization:- Programming that remove user input that can be interpreted as code
- ③ Input validation:- ensure user input meets System's expectation

SQL injection Categories

- ① In band
- ② Out of band
- ③ Inferential

① In band:- or classic SQL injection is most common type. It uses the same communication channel to launch the attack and gather the result

Ex show returned item in entry box

② Out-of-band SQL injection:- use different communication channel to launch the attack and gather the result

Ex Create connection between a vulnerable website and a database they control

③ Inferential SQL injection:- It occurs when attacker is directly unable to see result of attack but they can interpret the behaviour of the system

Threat Modeling

Steps of threat Modeling

- ① Define the Scope
- ② Identify threat
- ③ Characterize the environment
- ④ Analyze the threat
- ⑤ mitigate risk
- ⑥ Evaluate finding

PASTA :- The process of Attack Simulation and threat analysis

PASTA A popular threat modeling framework that used across many industries

7 Stages of PASTA

- ① Define business and security objective
- ② Define the technical Scope
- ③ Decompose The Application
- ④ Perform Threat analysis
- ⑤ Perform vulnerability analysis
- ⑥ Threat modeling
- ⑦ analyse risk and impact

Common Threat modeling framework

- STRIDE
- Trike
- PASTA
- VAST

STRIDE

STRIDE is a threat-modeling framework developed by Microsoft. It's commonly used to identify vulnerabilities in six specific attack vectors. The acronym represents each of these vectors: spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege.

PASTA

The **Process of Attack Simulation and Threat Analysis** (PASTA) is a risk-centric threat modeling process developed by two OWASP leaders and supported by a cybersecurity firm called VerSprite. Its main focus is to discover evidence of viable threats and represent this information as a model. PASTA's evidence-based design can be applied when threat modeling an application or the environment that supports that application. Its seven stage process consists of various activities that incorporate relevant security artifacts of the environment, like vulnerability assessment reports.

Trike

Trike is an open source methodology and tool that takes a security-centric approach to threat modeling. It's commonly used to focus on security permissions, application use cases, privilege models, and other elements that support a secure environment.

VAST

The Visual, Agile, and Simple Threat (VAST) Modeling framework is part of an automated threat-modeling platform called ThreatModeler®. Many security teams opt to use VAST as a way of automating and streamlining their threat modeling assessments.